



UNIVERSIDAD POLITECNICA DE SAN LUIS POTOSI
Act17: Evaluación de vulnerabilidades con CVSS v3.1.

Carrera: ITI

Asignatura: CNO V Seguridad Informática

Salazar Hernández Pablo de Jesús - 171580

Cavazos Zacarías Rodolfo – 178823

Nieto Diaz de León Jair de Jesús – 171676

Gutiérrez Hernández Rodolfo – 179598

Morquecho Medina Eduardo Gabriel – 175805

Bustamante Rocha Cristopher Leonardo – 173754

Mtro. Servando López Contreras

11/05/2026

Índice

Introducción	2
Marco Teórico	3
Métricas de Explotabilidad	3
Métricas de Impacto	4
Escenario	5
Construcción del vector CVSS	5
Interpretación técnica	6

Introducción

En el ámbito de la ciberseguridad organizacional, la identificación y evaluación de vulnerabilidades constituye una actividad crítica para la gestión del riesgo. Sin embargo, no basta con detectar una falla técnica, es indispensable cuantificar su gravedad de manera objetiva, reproducible y comparable, de modo que los equipos de seguridad puedan priorizar sus acciones de mitigación con base en criterios técnicos sólidos.

La presente actividad aplica el modelo CVSS v3.1 sobre un escenario técnico real con el objetivo de construir correctamente una cadena vector, calcular la puntuación base resultante e interpretar su significado en un contexto organizacional, desarrollando así las competencias necesarias para la priorización de riesgos en operaciones de seguridad ofensiva y defensiva.

Marco Teórico

El **Common Vulnerability Scoring System (CVSS) v3.1** es un estándar utilizado para medir la gravedad de una vulnerabilidad de seguridad. Su objetivo es proporcionar una puntuación numérica que permita comparar y priorizar vulnerabilidades de acuerdo con su facilidad de explotación y el impacto que pueden generar.

La puntuación base se obtiene a partir de dos subgrupos:

- **Métricas de explotabilidad:** describen las condiciones necesarias para explotar la vulnerabilidad.
- **Métricas de impacto:** describen las consecuencias sobre la confidencialidad, integridad y disponibilidad del sistema.

Métricas de Explotabilidad

Attack Vector (AV): Describe el contexto desde el cual es posible explotar la vulnerabilidad. Determina qué tan accesible es el componente vulnerable para un atacante potencial. Sus valores son:

- Network (N): La vulnerabilidad es explotable de forma remota a través de la red, sin necesidad de acceso físico. Representa el mayor nivel de exposición.
- Adjacent (A): Requiere que el atacante esté en la misma red lógica o física (LAN, Bluetooth, Wi-Fi).

- Local (L): El atacante necesita acceso local al sistema, ya sea mediante sesión directa o a través de interfaces locales.

- Physical (P): Requiere interacción física directa con el hardware del sistema afectado.

Attack Complexity (AC) :Refleja las condiciones técnicas que deben existir, más allá del control del atacante, para que la explotación sea posible. Sus valores son:

- Low (L): No se requieren condiciones especiales. El ataque puede repetirse con éxito en cualquier momento sin factores adicionales.

- High (H): Existen condiciones de difícil reproducción: evasión de mecanismos de seguridad, condiciones de carrera, o configuraciones específicas necesarias.

Privileges Required (PR): Indica el nivel de acceso autenticado que debe poseer el atacante antes de poder ejecutar el ataque. Sus valores son:

- None (N): No se requiere autenticación previa.

- Low (L): Se necesitan privilegios básicos de usuario sin capacidades administrativas.

- High (H): Se requieren privilegios elevados, como acceso administrativo o de superusuario.

User Interaction (UI): Determina si la explotación requiere la participación activa de un usuario legítimo distinto al atacante. Sus valores son:

- None (N): El atacante puede explotar la vulnerabilidad sin ninguna intervención del usuario.

- Required (R): Un usuario debe realizar alguna acción (abrir un archivo, hacer clic en un enlace) para que la explotación sea posible.

Métricas de Impacto

Scope (S): Determina si una vulnerabilidad explotada puede afectar componentes fuera del alcance del sistema vulnerable original (componente autorizado). Sus valores son:

- Unchanged (U): El impacto se limita al componente vulnerable; no se afectan recursos de otros componentes.

- Changed (C): La explotación permite afectar recursos más allá del componente original, como otros servicios, sistemas o dominios de seguridad.

Confidentiality (C): Mide el impacto sobre la protección de la información ante accesos no autorizados. Sus valores son:

- None (N): No existe impacto sobre la confidencialidad del sistema.
- Low (L): Hay acceso limitado a información; no se comprometen datos críticos ni se obtiene control total sobre la información disponible.
- High (H): Se produce divulgación total de información, incluyendo datos sensibles o credenciales del sistema.

Integrity (I): Evalúa el impacto sobre la exactitud y confiabilidad de la información gestionada por el sistema. Sus valores son:

- None (N): No existe impacto sobre la integridad del sistema.
- Low (L): Es posible modificar datos de forma limitada, sin afectar funciones críticas ni comprometer la confianza total del sistema.
- High (H): El atacante puede modificar cualquier dato del sistema, con consecuencias graves sobre su operación o confiabilidad.

Availability (A): Mide el impacto sobre la accesibilidad y operatividad del sistema o servicio afectado. Sus valores son:

- None (N): No existe impacto sobre la disponibilidad del sistema.
- Low (L): El rendimiento del sistema se ve reducido o se producen interrupciones intermitentes, sin llegar a una denegación total del servicio.
- High (H): El atacante puede provocar una pérdida total de disponibilidad, dejando el sistema completamente inaccesible.

Escenario

Una organización detecta una vulnerabilidad en un sistema web interno con las siguientes características:

1. Puede explotarse a través de la red.
2. La explotación requiere baja complejidad.
3. Se necesitan privilegios elevados.
4. No requiere interacción del usuario.
5. No cambia el alcance.
6. El impacto en,
 - Confidencialidad: Bajo.
 - Integridad: Bajo.
 - Disponibilidad: Bajo.

Construcción del vector CVSS

Basándonos enteramente en el escenario planeado, la cadena de vector es la siguiente:

Base Score

4.7
(Medium)

Attack Vector (AV)

Network (N)

Adjacent (A)

Local (L)

Physical (P)

Attack Complexity (AC)

Low (L)

High (H)

Privileges Required (PR)

None (N)

Low (L)

High (H)

User Interaction (UI)

None (N)

Required (R)

Scope (S)

Unchanged (U)

Changed (C)

Confidentiality (C)

None (N)

Low (L)

High (H)

Integrity (I)

None (N)

Low (L)

High (H)

Availability (A)

None (N)

Low (L)

High (H)

Vector String -
CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:L/I:L/A:L

CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:L/I:L/A:L

Métrica	Valor	Justificación
AV	N	La vulnerabilidad puede explotarse a través de la red.
AC	L	La explotación requiere baja complejidad.
PR	H	Se necesitan privilegios elevados.
UI	N	No requiere interacción del usuario.
S	U	No cambia el alcance del sistema afectado.
C	L	El impacto en confidencialidad es bajo.
I	L	El impacto en integridad es bajo.
A	L	El impacto en disponibilidad es bajo.

Interpretación técnica

La puntuación final de 4.7 sitúa esta vulnerabilidad en el rango de Severidad Media. Aunque técnicamente el ataque es sencillo de ejecutar, debido a su Complejidad Baja (AC:L), y puede realizarse a través de la red mediante Vector de Red (AV:N), el cálculo de CVSS v3.1 reduce la severidad debido al requisito de Privilegios Elevados (PR:H). Esto significa que el atacante no puede explotar la vulnerabilidad desde una posición

no autenticada o con permisos básicos, sino que primero debe contar con privilegios altos dentro del sistema.

- **Vector de Ataque (AV:N):** La vulnerabilidad es explotable de forma remota a través de la red, por lo que el atacante no requiere acceso físico ni local al servidor. Esto aumenta el nivel de exposición del sistema.
- **Complejidad de Ataque (AC:L):** No existen condiciones especiales para que el ataque tenga éxito. Una vez que el atacante cuenta con los privilegios requeridos, la explotación puede ejecutarse de forma directa.
- **Privilegios Requeridos (PR:H):** Este es el principal factor que reduce la severidad. El atacante necesita previamente una cuenta con permisos elevados, lo que disminuye la cantidad de posibles atacantes capaces de explotar la vulnerabilidad.
- **Interacción del Usuario (UI:N):** La explotación no requiere que un usuario legítimo realice alguna acción, como abrir un archivo o hacer clic en un enlace. Esto facilita que el ataque pueda ejecutarse de manera autónoma.
- **Impacto (C:L, I:L, A:L):** El impacto es bajo en confidencialidad, integridad y disponibilidad. Esto significa que la vulnerabilidad puede afectar parcialmente la información, modificar datos de forma limitada o causar afectaciones menores al servicio, pero no compromete completamente el sistema.